

Transformers has a Deserialization of Untrusted Data vulnerability in [huggingface/transformers](#)

✓ Valid

Reported on Feb 3rd 2024

Proof of Concept

Description

Transformers contains a **Deserialization of Untrusted Data vulnerability** within the `load_repo_checkpoint()` function under the `TFPreTrainedModel()` class. This vulnerability enables attackers to **execute arbitrary code and commands by using a carefully crafted serialized payload**.

Proof of Concept

```
#poc.py
from transformers import TFAutoModel
from tensorflow.keras.optimizers import Adam
model = TFAutoModel.from_pretrained('bert-base-uncased')
model.compile(optimizer=Adam(learning_rate=5e-5), loss='sparse_categorical_crossentropy')

model.load_repo_checkpoint('Retr0REG/EvanModel')
```

Tree of Repo `Retr0REG/EvanModel`; These file are modified by a saved `TFAutoModel.from_pretrained('bert-base-uncased')`; `weights.h5` is required to make sure `*self*.load_weights(weights_file)` do not throw a exception, which is copied from `tf_model.h5`; `model.compile` is only used make sure `if getattr(self, "optimizer", None) is None:` passes, which seems reasonable and logical since checkpoint also restore optimizer's state

```
▲ ~/poc/EvanModel tree
.
├── EvanModel
├── README.md
├── checkpoint
│   ├── extra_data.pickle
│   └── weights.h5
├── config.json
└── tf_model.h5
```

Inside of Retr0REG/EvanModel; `checkpoint/extra_data.pickle` Contains a payload that is generated via:



↑ Ruikai Peng submitted a patch 2 years ago



↑ Ruikai Peng submitted a patch 2 years ago



✎ Ruikai Peng modified the report 2 years ago



✎ Ruikai Peng modified the report 2 years ago



✎ Ruikai Peng modified the report 2 years ago



✎ Ruikai Peng modified the report 2 years ago



✎ Ruikai Peng modified the report 2 years ago



Ruikai Peng commented 2 years ago

Researcher

I would recommend to view <https://huntr.com/bounties/ela3e548-e53a-48df-b708-9ee62140963c/>, this same advance exploitation method still works under this vulnerability.

✉ We have contacted a member of the **huggingface/transformers** team and are waiting to hear back 2 years ago



✎ Ruikai Peng modified the report 2 years ago



✎ Ruikai Peng modified the report 2 years ago

✉ We have sent a follow up to the **huggingface/transformers** team. We will try again in 4 days. 2 years ago



A **huggingface/transformers** maintainer has acknowledged this report 2 years ago

✎ The scheduled publication date was automatically extended from 20th Mar 2024 to 27th Mar 2024 due to the maintainers acknowledgement of the report 2 years ago

✎ Michelle Habonneau modified the Severity from Critical (9.6) to Low (3.4) 2 years ago



Ruikai Peng commented 2 years ago

Researcher

Dear maintainer, the vulnerability reported allows **directly remote code execution** on client machines. The ratings of *Confidentiality*, *Integrity*, and *Availability* were adjusted from High to Low, I am concerned that this adjustment may not accurately reflect the severity of the issue at hand.

As demonstrated in the proof of concept, the vulnerability enables attackers to execute arbitrary code in victim's machine by inducing them to load a seemingly harmless checkpoint during a routine training process. This exploitation can lead to significant breaches of confidentiality and integrity, allowing attackers to access sensitive information, modify data, or disrupt the availability of the system, while allowing **advanced exploitation** similar mentioned in [This huntr report](#)

Additionally, it is my understanding that transformers may still contain approximately five instances of unsafe use of pickle. However, my focus has been primarily on this particular vulnerability, as it uniquely facilitates remote code execution via the Hugging Face community, a risk not addressed in the latest TRUST_REMOTE_CODE update.



Ruikai Peng commented 2 years ago

Researcher

CVEs such as CVE-2021-27475 and CVE-2018-17456 both exploit "user trust" in some way, with that trust being based on the user's confidence in the project or its reputation. However, the act of **loading a checkpoint on Hugging Face causing an RCE is definitely not an expected outcome for users**. Similar to this case, vulnerabilities that 'justify' the deployment of a malicious payload placed a risk that must be concern—especially when they open up the possibility of remote attack vectors. Such potential for exploitation cannot be ignored.

★ The researcher has received a minor penalty to their credibility for miscalculating the severity: -1

✓ **Michelle Habonneau** validated this vulnerability 2 years ago

Thanks for your report! A fix has been applied - <https://github.com/huggingface/transformers/pull/28926>.

\$ **retr0reg** has been awarded the disclosure bounty ✓

\$ The fix bounty is now up for grabs

★ The researcher's credibility has increased: +7



Ruikai Peng commented 2 years ago

Researcher

May we disclose this report since it's fixed?

Michelle Habonneau commented 2 years ago

Maintainer

Hi Patrick Peng! We're working on resolving this report and will "mark as fixed" here soon. The publication date is currently set for March 27th. About the update to severity: the function does indeed call `pickle.load()` which permits remote code execution from an untrusted repo - however, this function is essentially deprecated and unused code that is not called in any standard workflow, so the attacker would have to induce the user to call this unusual function in addition to preparing a repo with a malicious payload.

✓ Michelle Habonneau marked this as fixed in 4.38 with commit 693667 2 years ago

\$ The fix bounty has been dropped ✖

\$ modeling_tf_utils.py#L1401 has been validated ✓



Ruikai Peng commented 2 years ago

Researcher

Dear Maintainer, may I request a CVE on this report?

⚠ We have sent a warning to the huggingface/transformers team to inform them that this report will be published in 48 hours 2 years ago

📡 This vulnerability has now been published 2 years ago

🛡 CVE-2024-3568 assigned to this report. 2 years ago

🛡 CVE-2024-3568 has now been published 2 years ago

[Sign in](#) to join this conversation

CVE

CVE-2024-3568

Published

Vulnerability Type

CWE-502: Deserialization of Untrusted Data

Severity

Low (3.4)

Attack vector	Network
Attack complexity	High
Privileges required	None
User interaction	Required
Scope	Changed
Confidentiality	None
Integrity	None
Availability	Low

[Open in visual CVSS calculator](#) ↗

Registry

Pypi

Affected Version

4.37.2 (Latest)

Visibility

Public

Status

Fixed

Disclosure Bounty

\$20

Fix Bounty

\$5

Found by



Ruikai Peng

@retr0reg

MIDDLEWEIGHT



Supported by [Palo Alto Networks](#) and Prisma AIRS, leading the way to greater AI security.



© 2024

[Privacy Policy](#)

[Terms of Service](#)

[Code of Conduct](#)

[Cookie Preferences](#)

[Contact Us](#)